



[Blog](#)

[ISO 27001](#)

ISO 27001 Controls: A Guide to Implementing Annex A Controls

ISO 27001 Controls: A Guide to Implementing Annex A Controls



Gowsika

Sep 19, 2024



Talk to an expert



ISO 27001 is an international standard that outlines various clauses and controls that organizations can implement for effectively building an Information Security Management System (ISMS).

The ISO 27001 clauses and controls are utilized by organizations to manage security risks and achieve ISMS certification. The controls are detailed in Annex

A, and organizations should choose and deploy the relevant controls. These controls will help mitigate the identified security risks, establishing a robust framework.

Read this article to learn about the 114 ISO 27001 Annex A controls, compliance steps, and upcoming control list changes.

What are ISO 27001 Controls?

ISO 27001 controls are the measures that organizations must take by way of policies, processes, and procedures to meet the security requirements of the framework. ISO 27001 lists its 114 controls in Annex A which are divided into 14 domains.

ISO 27001 Annex A is like a Table of Contents that lists all the security controls under ISO. Organizations can pick and choose the appropriate

TABLE OF CONTENTS

What are ISO 27001 Controls?

Who is responsible for implementing ISO 27001 Annex A controls?

How many ISO 27001 clauses and controls are

controls and decide how they deploy them based on their risk assessment and risk treatment plan.

Who is responsible for implementing ISO 27001 Annex A controls?

Infosec Officer (or team) is responsible for the implementation of controls and the organization's compliance with ISO 27001 standard, the fundamental responsibility of implementing the Annex A controls vests on all the employees. Employees are the first line of defense in a security attack; therefore, it is a shared responsibility.

Management buy-in is critical here. Therefore, the entire process of ISO 27001 implementation rests equally on management review and approval of policies and

How many ISO 27001 clauses and controls are there?

What are the 14 domains under ISO 27001 list of controls?

How to identify which ISO 27001 Security Controls you should implement?

ISO 27001 Annex A controls vs ISO 27002

Fast-track your ISO 27001 journey

Final Thoughts

FAQs

Subscribe to Ctrl+GRC

Go beyond the surface and uncover the governance, risk, and compliance insights that actually matter.

Work Email

Subscribe Now

Pre-mapped Annex A controls in minutes

Get access



procedures at every decisive step.

How many ISO 27001 clauses and controls are there?

ISO 27001 includes 11 core clauses that define the requirements for an Information Security Management System ([ISMS](#)), supported by 93 security controls in Annex A. These controls are grouped into four categories: organizational, people, physical, and technological. For AI-first companies, these controls extend beyond IT to address data governance, access management, and operational risks across automated and human systems.

Here's a peek at how they stack up:

Function	Number of Controls	Annex A
 Organizational Issues	24	A.5, A.6., A.8, A.15
 Human Resources	6	A.7
 Information Technology	61	A.9, A.10, A.12, A.13, A.14, A.16, A.17
 Physical Security	15	A.11
 Legal Issues	8	A.18

These controls cover the technologies, policies, and processes an organization uses to build and maintain its information security management system (ISMS). All the controls are written in a way that allows different organizations and businesses to meet ISO 27001 requirements in their own way.

Organizations, however, must compulsorily meet the requirements from Clauses 4-10 of the ISO 27001 to claim compliance. In other words, organizations can achieve certification to ISO 27001 only when they meet all the requirements in Clauses 4 through 10.

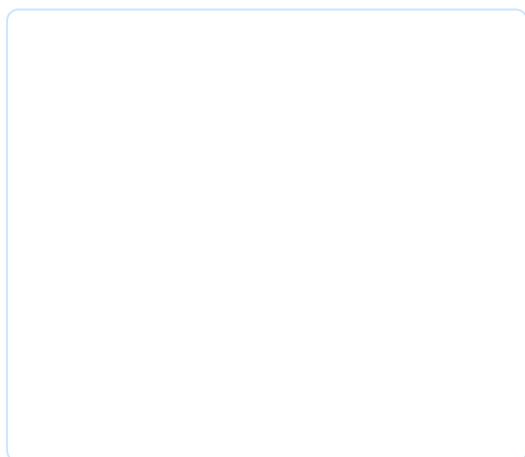
Getting ISO 27001 audit-ready?

Sprinto can help you get
certified in
4 easy steps.

Talk to us

[Learn more >](#)

4 through 10 of the ISO 27001
clauses are mandatory for
certification:



Finding the right ISO 27001
automation solution:

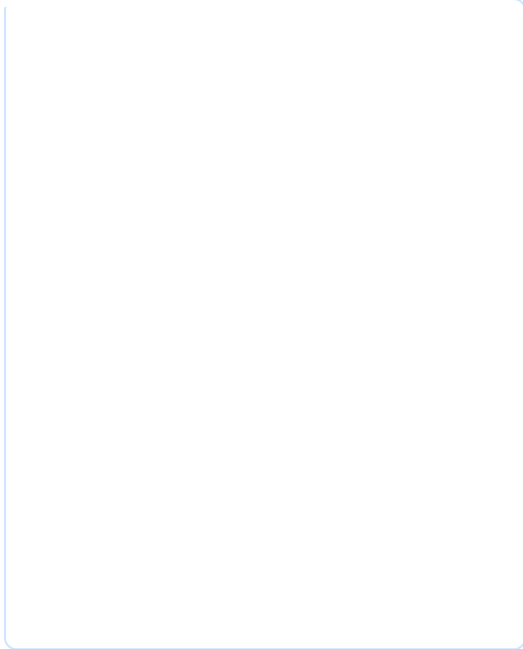
With Sprinto's tech-enabled solution – automated evidence collection, structured implementation of security controls, and continuous monitoring – you can get the audit ready in days. [Talk to us now!](#)

**Implement ISO Controls
with Zero Guesswork Using
Sprinto**

[Book a Demo](#)

What are the 14 domains under ISO 27001 list of controls?

ISO 27001 Controls List comprises 14 domains, each centered on specific security functions within the organization.



These are the 14 domains of ISO 27001 annex a controls list explained in detail:

1. Information Security Policies – Annex A5

As per the List of ISO 27001 controls here it determines if your organization has policies to provide management direction and support for information security. The organization needs to document relevant infosec policies and ensure they are approved by the management, published and communicated for staff awareness and reviewed periodically.

Though the domain has only two controls, it is perhaps the most important one as it sets the tone for the organization-wide information security standards.

ToDo:

- Documentation of your infosec policies
- Process for infosec policies' approval, communication, and review

2. Organisation of Information Security – Annex A6

If A5 was about setting up the [information security policies](#) and processes, A6 is about ensuring how the policies are implemented in the organization. The Annex provides a framework for assigning security roles across the organization such that no one drops the ball while implementing and running the ISMS. It also

covers mobile devices and remote working.

While a lone infosec officer can spearhead the policy implementations for startups or smaller organizations, it's a good practice to have a plan in place for the same as your organization grows.

ToDo's:

- Detailed organization structure with roles, reporting structure, job descriptions & responsibilities
- Process for ensuring data security for remote workers and vendors

Operationalizing Ann...



3. Human Resources Security – Annex A7

Much like the human resources function, the controls in this domain are

centered on information security through the three phases of employees' journey in an organization – before employment, during employment and on termination/change of employment.

These include background verification and mention of infosec responsibilities in the terms and conditions of employment, infosec [awareness training](#) on the job, disciplinary processes in case of security breaches, and policies implemented to ensure data security is maintained even after employees leave the organization.

ToDo's:

- Policies and relevant documentation/proof to demonstrate how every hire in the organization are evaluated
- Background checks & verification

- Policies and proof to showcase that every employee undergoes [periodic security training](#)
- Employee acknowledgment of the organization's information security policies
- Policies and proof of how the organization ensures data security after employees leave the organization

4. Asset Management – Annex A8

ISO 27001 Annex A controls in this domain help identify organizational assets (associated with information management) and define appropriate protection responsibilities.

It includes asset identification within the scope of the ISMS to its classification (confidential, restricted, internal and public) and access and media handling to prevent unauthorized

disclosure, modification,
removal or destruction of
information stored on media.

ToDo:

- Proof to demonstrate how your organization ensures restricted access to all critical systems
- Data Encryption and media disposal procedure

5. Access Control – Annex A9

An important facet of data security is controlling access to information, and this domain defines the controls to do just that. Access control, in essence, is user management that defines controls for the administration of login credentials, user privileges, access rights, and password management systems, to name a few.

It also includes access privileges of clients, applications, secure login procedures and controlled

access to program source codes.

ToDo:

- Proof of organization-wide access control and its periodic review
- User privilege and access rights to the production database
- Evidence of termination of access to organization's information assets on offboarding

6. Cryptography – Annex A10

Your organization should have a documented policy on cryptographic controls and key management processes.

The objective of this domain is to ensure the confidentiality, integrity and availability of information are protected throughout. The policy should include details on the use, protection and lifetime of cryptographic keys.

ToDo:

- Proof that all production database[s] that store customer data are encrypted at rest
- Documented encryption policy that's made available for all staff on the company intranet
- Proof that endpoints with access to production systems are encrypted to protect them from unauthorized access

7. Physical and Environmental Security – Annex A11

The control objectives for this domain focus on protecting your organization's physical premises and preventing loss, damage, theft or compromise of its assets and operations. It does so by laying out controls to prevent unauthorized physical access, damage and interference with the organization's ISMS.

Securing your premises,
physical entry access

controls, protection of the environment against natural disasters, clear desk and clean screen, unattended user equipment, authorized removal of assets and their secure disposal are other areas covered in this domain.

ToDo:

- Proof that company-owned endpoints are configured to auto-screen-lock after 15 minutes of inactivity
- Production systems are encrypted from unauthorized access

8. Operational Security – Annex A12

Comprising seven sub-domains, the controls listed here pertain to operational procedures, defenses against malware, backups, logging & monitoring, change management, patch management, vulnerability management and penetration tests, and more. But more

importantly, like anything in ISO 27001, it all needs to be documented.

ToDo's:

- Proof to demonstrate that endpoints with access to production systems are protected by malware-protection software
- [Proof of periodic ISO 27001 audits](#) of employee endpoints to ensure security patches are applied and the Operating System version is current (or the next most current)
- Vulnerability scans, pen tests, business continuity & disaster recovery policies, among others

We've covered all of these points in our [ISO 27001 audit checklist](#).

9. Communications Security – Annex A13

Network security, segregation of networks, secure transfer of information, confidentiality

and non-disclosure agreements are some of the critical controls in this domain. It governs how organizations protect their data in networks.

A13.1 dwells on network security management and ensures that information security, confidentiality, integrity and availability are maintained throughout. A13.2 pertains to information on the move – to a different organization, third party or customer.

ToDo's:

- Network service agreements detailing the security mechanisms, service levels and management requirements of all network services
- Data classification policy, Confidentiality policy, firewall with a deny-by-default rule

10. System Acquisition, Development and

Maintenance – Annex A14

The first objective of A14 is to ensure that information security is integral to information systems across the entire lifecycle. So, data security should remain paramount for any changes made to the information security system or when a new system replaces the existing one.

The ISO 27001 controls cover the security requirements for internal systems and public networks. It also includes the controls for securing the software development life cycle (SDLC).

11. Supplier Relationships – Annex A15

Vendor risk management is critical to managing your organization's information security management system. The ISO 27001 controls here protect your organization's

assets accessible to the suppliers. Contractual agreements your organization has with its suppliers come under the purview of this domain.

You must demonstrate that you also hold your suppliers to a strict security standard.

ToDo:

- Proof of periodic vendor risk assessments conducted to identify vendors critical to the systems' security commitments and requirements.
- Senior Management review and approval of 'Vendor Risk Assessment Report' annually
- Documented Vendor Management Policy that guides staff on [performing a risk assessment](#) of third-party vendors

12. Information Security Incident Management –

Annex A16

This domain deals with controls that define the roles and responsibilities of employees when things go wrong (aka, there is a security breach). Who should be informed in the case of a breach? Who can make decisions? What are the must-dos in case of a breach?

The controls here detail the incident response and reporting process in case of a security incident and require defining the corrective action after one. Learnings and collection of evidence are also included here.

ToDos:

- Continuous monitoring system with periodic review access
- Policies and procedures for production assets to generate alerts and action in case of a threat
- Maintain a record of information security

incidents

13. Information Security Aspects of Business Continuity Management – Annex A17

Information security is critical. And it is especially so when facing business disruption, such as a natural disaster, acquisition, or political upheaval, to name a few. This domain requires the organization to have a plan of action in such events.

The first section addresses information security continuity, and the second focuses on redundancies to ensure information processing facilities' availability.

ToDos:

- Document and communicate your Business Continuity & Disaster Recovery Policies that establish guidelines and procedures on continuing business operations in case of a

disruption or a security
incident

- Restore and test data
backups annually
- Test and document
learnings from the
periodic running of the
disaster recovery plan

Get a wingman for your ISO 27001 audit!

See how Sprinto expedites
audit-preparedness to just
weeks.

Quick demo

[Learn more >](#)

14. Compliance – Annex A18

The last domain ensures
organizations identify the
relevant and applicable laws

and regulations, such as intellectual property rights, privacy, and protection of personally identifiable information, and how they abide by them. It also includes how organizations mitigate the risk of non-compliance and penalties.

To Dos:

- Proof to show access Control and restricted use of data
- Media disposal policy
- Periodic vulnerability and pen testing
- Data protection, data retention, and data classification policies on the company's intranet

Experience the Sprinto

Advantage:

Implementing the complete list of ISO 27001 domains and controls is a cumbersome task. But it can be simplified with the help of

a compliance automation tool like [Sprinto](#).

Sprinto enables you to implement controls, amend existing ones, and monitor them on an ongoing basis.

Want to learn more? [See Sprinto in action](#).

Also find out: [How all of these controls can be automated](#)

How to identify which ISO 27001 Security Controls you should implement?

To determine which ISO 27001 security controls to implement, organizations should begin with a thorough risk assessment. This helps identify the threats most relevant to your business and informs a treatment plan tailored to your actual risks—not just the checkbox. From there, controls can be prioritized based on your specific vulnerabilities,

operating environment, and
compliance goals

Download your **ISO
27001**

Gap Analysis
Template Now

First name*

Email*

☐

Are you currently evaluating cyber
compliance automation?

Download Now

Case Study

Check out how

[Officebeacon achieved
compliance](#) maturity and



breezed through the ISO
27001 audit using Sprinto

ISO 27001 Annex A controls vs ISO 27002

The ISO 27002 mirrors the ISO 27001 Annex A controls but focuses on aspects of implementation. The ISO 27002 saw a slew of changes recently. We can consider the [changes made in ISO 27002:2022](#) as a helpful guide to prepare for the changes to ISO 27001 by the end of the year.

So, if your organization is currently assessing against ISO 27001, it's worth incorporating the 11 new controls into your review process. And if you're just beginning your compliance journey, addressing these additions early on can help future-proof your ISMS—especially when you understand how they map out

in the context of [ISO 27001 vs ISO 27002](#).

Or better still, [book a demo](#) with us and see how Sprinto can make compliance easy, error-free and fast for you.

Fast-track your ISO 27001 journey

When you work with Sprinto, we do all the heavy lifting in drafting the policies (sans legal speak and editable), evidence collection and [continuous monitoring](#). Our team of experts walk you through the [ISO 27001 compliance requirements](#), risk assessment and treatment plan and help you make the right choice of controls from Annex A. And that's not all. Sprinto's automated compliance platform makes you audit-ready within weeks and keeps you on top of your compliance game, whether there's an audit or not.

[Talk to our team](#) and learn more about how Sprinto can partner in your compliance journey.

Final Thoughts

So, that was all about ISO 27001 Annex A controls. Annex A is an important document for effectively meeting the ISO 27001 requirements. Once you have identified the controls that will be implemented, you can refer to ISO 27002 for more information.

To make your ISO 27001 journey a seamless ride, you can tune in to the Sprinto way to put your compliance ventures in auto-pilot mode. [Book a demo](#) with us and see how Sprinto can make compliance easy, error-free, and fast for you.

FAQs

How many controls does the ISO 27001 Annex A have?

There are a total of 114 controls in the ISO 27001 Annex A that are divided into 14 domains. The 114 controls in general come under different functions i.e. organizational issues, human resources, information technology, physical security, and legal issues.

Are Annex A controls mandatory?

No, it isn't mandatory to implement all 114 ISO 27001 controls listed under Annex A. You can select the controls that apply to your organization based on the risk profile.

What is the primary purpose of Annex A controls?

The primary purpose/objective of Annex A controls is to improve the

security of the organization's information assets.

What is ISO 27001 Annex A statement of applicability?

The Statement of Applicability is an important document when it comes to ISO standards. It defines which controls from the 114 you will implement and how. It also states the reason for not implementing certain controls.

Why does Annexure A start with 5 in ISO 27001?

You might notice the controls in Annex A start at A5 instead of A1. This corresponds to a related ISO standard, ISO 27002, that has sections 1-4 as introductions before the controls begin in section 5. So when Annex A was created for ISO 27001, it just continued the numbering from ISO 27002. The controls you see in Annex A match up with the

controls outlined in sections 5 and beyond of [ISO 27002 controls list](#).

What are the 14 domains under ISO 27001 list of controls?

ISO 27001 outlines 14 domains of controls under Annex A.

They provide a comprehensive framework for managing information security and these domains are:

- A5: Information Security Policies
- A6: Organization of Information Security
- A7: Human Resources Security
- A8: Asset Management
- A9: Access Controls
- A10: Cryptography
- A11: Physical and Environmental Safety
- A12: Operation Security

- A13: Communication Security
- A14: System Acquisition, Development and Maintenance
- A15: Supplier

Gowsika

Gowsika is an avid reader and storyteller who untangles the knotty world of compliance and cybersecurity with a dash of charming wit! While she's not decoding cryptic compliance jargon, she's oceanside, melody in ears, pondering life's big (and small) questions. Your guide through cyber jungles, with a serene soul and a sharp pen!

Explore more ISO 27001 articles

ISO 27001 Overview & Requirements

- What is ISO 27001 Compliance

- ISO 27001 Requirements List
- ISO 27001 Certification
- ISO 27001 Certification Cost
- ISO 27001 Checklist
- ISO 27001 Controls List

ISO 27001 vs Other Frameworks

- Difference between SOC 2 vs ISO 27001
- Difference between NIST vs ISO 27001
- Difference between GDPR vs ISO 27001
- Difference between ISO 27001 vs ISO 27002
- Map SOC 2 Criteria to ISO 27001 Standards

ISO 27001 Audit & Certification Process

- ISO 27001 Audit Guide
- ISO 27001 Audit Checklist
- ISO 27001 Internal Audit
- ISO 27001 Surveillance Audit
- ISO 27001 Lead Auditor Training
- ISO 27001 Mandatory Documents

ISO 27001 Management & Assessment

- ISO 27001 Risk Assessment
- ISO 27001 Risk Assessment Policy
- ISO 27001 Vulnerability Management
- ISO 27001 Disaster Recovery Plan
- ISO 27001 Risk Treatment Plan
- ISO 27001 Policy Templates
- ISO 27001 Statement of Applicability

ISO 27001 Implementation & Automation

- ISO 27001 Automation
- ISO 27001 Softwares
- ISO 27001 Gap Analysis Process
- ISO 27001 Incident Management
- ISO 27001 Business Continuity

ISO 27001 Industry-Specific Applications

- ISO 27001 for Startups
- ISO 27001 for Small Business
- ISO 27001 for SaaS
- ISO 27001 for Fintech
- ISO 27001 for Cloud
- ISO 27001 for Healthcare

Tired of fluff GRC and cybersecurity content?

Subscribe to our newsletter and get detailed research & insights curated to help you earn a seat at the table.

Submit

Sprinto is Great Place to Work- Certified

COMPANY

About

FREE RESOURCES

Support

Compliance Cost Calculator

Contact Us

FRAMEWORKS

Compliance Effort Calculator

Careers HIRING

SOC 2

Compliance Overlap Calculator

Refer And Earn \$500

ISO

Compliance Templates

Cloud Compliance

Migration

USE CASES

Mid-Market (GRC)

GDPR Program

Continuous Compliance

See more..

ONETRUST CENTERS

Automated Evidence Collection

Login

SOC 2 Certification

Audit Readiness

GUIDES

ISO 27001 Certification

Risk Management

SOC 2 Compliance

PCI DSS Certification

ALTERNATIVES

ISO 27001 Compliance

HIPAA Certification

Vanta Alternatives

NIST Compliance

NIST Certification

Data Alternatives

GDPR Compliance

SOC 2 Checklist

Scrut Alternat

HIPAA Compli

ISO 27001 Ch

Business email*

Secureframe

See more

NIST Compliance Checklist

Onetrust Alternatives

[See more..](#)

Submit

HIPAA Compliance Checklist

CMMC Compliance Checklist

[See more..](#)

[Privacy](#) [Terms](#) [Security](#)

© 2025 Sprinto. All Rights Reserved